eQMS - API design

1. Overview

This document specifies the API surface for the Document Management Platform.
All endpoints are:

- **REST over HTTPS**
- **JSON-based**, except file upload/download
- **Authenticated via OIDC tokens**
- **Tenant-scoped**

All *modifying* operations (Create/Update/Delete) generate transactional audit events stored in the **Outbox** table.
All *read* operations generate asynchronous audit events published to a **Durable Queue**.

2. Authentication & Authorization

2.1 Authentication

- All APIs require a valid OIDC Bearer Token.
- JWT must include:
  - `sub` (user identifier)
  - `tenant_id` claim
  - `roles` array
  - `permissions` or `scope` (optional)

2.2 Authorization

- RBAC + ABAC enforced at the API layer.
- Common permissions:
  - `document.read`
  - `document.write`
  - `document.delete`
  - `compliance.audit.read` (Compliance Only)

3. Error Handling

Standard error envelope:

```
{
  "error": {
```

```
    "code": "string",
    "message": "string",
    "details": {}
  }
}

```

Common error codes:

- `Unauthorized`
- `Forbidden`
- `NotFound`
- `ValidationFailed`
- `Conflict`
- `InternalError`

4. API Endpoints

4.1 Document API

4.1.1 Create Document

POST /api/v1/documents

Creates a new document and generates a **transactional audit event** (CUD).

Request

```
{
  "title": "Label Protocol V2",
  "description": "Labeling procedure",
  "metadata": {
    "classification": "Controlled",
    "tags": ["labelling", "v2"]
  },
  "contentBase64": "...."
}

```

Responses

- **201 Created**
- **Audit:** Outbox entry generated in same DB transaction

4.1.2 Get Document Metadata

GET /api/v1/documents/{documentId}

Returns metadata only.

- **Audit:** READ access logged asynchronously → queue.

Response

```
{
  "documentId": "doc-123",
  "title": "Label Protocol V2",
  "version": 3,
  "classification": "Controlled",
  "tags": ["labelling", "v2"],
  "createdAt": "2024-05-03T12:00:00Z"
}

```

4.1.3 Get Document Content

GET /api/v1/documents/{documentId}/content

Streams file content.

- **Audit:** READ logged asynchronously, including fieldsReturned.

Response

- Binary stream
- Headers:
  - `Content-Type: application/pdf`
  - `Content-Disposition: attachment`

4.1.4 Update Document Metadata

PUT /api/v1/documents/{documentId}

Modifies metadata, creates a new version if configured.

- **Audit:** Outbox entry created in same transaction.

Request

```
{
  "title": "Label Protocol V3",
  "metadata": {
    "classification": "Controlled",
    "tags": ["label", "v3"]
  }
}

```

Response

- `200 OK`

4.1.5 Delete Document

DELETE /api/v1/documents/{documentId}

Soft delete.

- **Audit:** Outbox entry generated.

Response

- `204 No Content`

4.2 Document Version API

4.2.1 List Document Versions

GET /api/v1/documents/{documentId}/versions

Returns all historical versions of a document.

Query Parameters (optional)

- `startDate` / `endDate` — filter by creation timestamp
- `author` — filter by user
- `limit` / `offset` — pagination

Response

```
[
  {
    "version": 1,
    "createdAt": "2024-01-01T12:00:00Z",
    "author": "user-123",
    "description": "Initial release"
  },
  {
    "version": 2,
    "createdAt": "2024-03-15T09:45:00Z",
    "author": "user-456",
    "description": "Updated labeling info"
  }
]

```

4.2.2 Get Historical Document Metadata

GET /api/v1/documents/{documentId}/versions/{versionNumber}

Returns metadata for a specific version.

- **Audit:** READ logged asynchronously (fieldsReturned = metadata fields).

Response

```
{
  "documentId": "doc-123",
  "version": 2,
  "title": "Label Protocol V2",
  "classification": "Controlled",
  "tags": ["labelling", "v2"],
  "createdAt": "2024-03-15T09:45:00Z",
  "author": "user-456",
  "description": "Updated labeling info"
}

```

4.2.3 Get Historical Document Content

GET /api/v1/documents/{documentId}/versions/{versionNumber}/content

Streams file content for a historical version.

- **Audit:** READ logged asynchronously (fieldsReturned = content + metadata fields).

4.4 Tenant API

Create Tenant

POST /api/v1/tenants

Registers a new tenant in the system. Only admin/system operators can perform this action.

Request

```
{
  "name": "Acme Pharmaceuticals",
  "contactEmail": "admin@acme.com",
  "defaultDataClassification": "Controlled"
}

```

Response

- `201 Created`
- Returns:

```
{
  "id": "tenant-123",
  "name": "Acme Pharmaceuticals",
  "createdAt": "2025-11-15T12:34:56Z"
}
```

Get Tenant

GET /api/v1/tenants/{tenantId}

Retrieve tenant details.

- **Audit:** READ logged asynchronously for compliance.

List Tenants

GET /api/v1/tenants

Returns all tenants visible to the caller (system admin only).

4.5 User API

Create User

POST /api/v1/tenants/{tenantId}/users

Creates a user within a tenant. Includes initial roles/permissions.

Request

```
{
  "username": "john.doe",
  "email": "john.doe@acme.com",
  "roles": ["DocumentEditor", "DocumentViewer"],
  "permissions": ["document.read", "document.write"]
}

```

Response

- `201 Created`
- Returns:

```
{
  "userId": "user-123",
  "username": "john.doe",
  "roles": ["DocumentEditor","DocumentViewer"],
  "createdAt": "2025-11-15T12:34:56Z"
}

```

- **Audit:** Outbox entry generated in same transaction.

Get User

GET /api/v1/tenants/{tenantId}/users/{userId}

Retrieve user details.

- **Audit:** READ logged asynchronously → queue.

Update User

PUT /api/v1/tenants/{tenantId}/users/{userId}

Update user roles or permissions.

Request

```
{
  "roles": ["DocumentViewer"],
  "permissions": ["document.read"]
}

```

- **Audit:** Outbox entry generated.

4.2.4 Delete User

DELETE /api/v1/tenants/{tenantId}/users/{userId}

Soft delete or disable user.

- **Audit:** Outbox entry generated.

4.2.5 List Users

GET /api/v1/tenants/{tenantId}/users

Return all users in a tenant.

- **Audit:** READ logged asynchronously → queue.

4.3 Roles & Permissions API

4.3.1 Create Role

POST /api/v1/tenants/{tenantId}/roles

Define a new role for the tenant.

Request

```
{
  "roleName": "DocumentApprover",
  "description": "Can approve documents for release",
  "permissions": ["document.read", "document.approve"]
}

```

Response

- `201 Created`
- Returns role details and assigned permissions.
- **Audit:** Outbox entry generated.

Get Role

GET /api/v1/tenants/{tenantId}/roles/{roleName}

Retrieve role details and permissions.

- **Audit:** READ logged asynchronously.

Update Role

PUT /api/v1/tenants/{tenantId}/roles/{roleName}

Update permissions for a role.

- **Audit:** Outbox entry generated.

Delete Role

DELETE /api/v1/tenants/{tenantId}/roles/{roleName}

Remove a role.

- **Audit:** Outbox entry generated.

List Roles

GET /api/v1/tenants/{tenantId}/roles

Return all roles in a tenant.

- **Audit:** READ logged asynchronously → queue.

5. Access Logging (READ Audit)

5.1 How the API logs

For every read endpoint (metadata or content), the API pushes this message to the queue:

```
{
  "eventId": "uuid",
  "tenantId": "uuid",
  "timestamp": "2025-10-23T12:34:56Z",
  "userId": "u-123",
  "action": "Document.View",
  "objectType": "Document",
  "objectId": "doc-123",
  "fieldsReturned": ["title", "version"],
  "sourceIp": "1.2.3.4"
}

```

API does **not** wait for audit persistence.

6. Compliance Audit API (Read Only) - Next phase

6.1 Query Audit Index

GET /api/v1/audit

Returns records from the metadata index (NOT blob data).

Query parameters

- `tenantId={uuid}`
- `start={ISO}`
- `end={ISO}`
- `action={string}`
- `objectType={string}`
- `objectId={string}`
- `actor={string}`
- `limit=200`

Example:

```
GET /api/v1/audit?tenantId=...&start=2025-01-01&end=2025-01-
31&action=Document.View

```

Response

```
{
  "items": [
    {
      "eventId": "uuid",
      "timestamp": "2025-01-12T14:33:45Z",
      "action": "Document.Update",
      "objectType": "Document",
      "objectId": "doc-22",
      "actor": "user-5",
      "blobUri": "blob://a/b/c.jsonl",
      "offset": 233
    }
  ]
}

```

6.2 Export Audit Trail (Blob-based)

POST /api/v1/audit/export

Generates a CSV, PDF, or JSON export from underlying immutable blob data.

Request

```
{
  "tenantId": "uuid",
  "start": "2025-01-01T00:00:00Z",
  "end": "2025-02-01T00:00:00Z",
  "format": "csv"
}

```

Response

- `202 Accepted`
- Returns jobId (export runs in background)

Download Result

GET /api/v1/audit/export/{jobId}/file

Compliance-only.

6.3 Get Raw Audit Event

GET /api/v1/audit/{eventId}

Fetches a single event by reading from blob using metadata offset.

7. System Internal APIs (Worker Side)

7.1 Outbox Forwarder Polling

Not exposed publicly, worker executes:

```
GET /internal/outbox/unprocessed
POST /internal/outbox/mark-processed

```

If these are implemented via direct DB connection, these internal APIs may not exist.

7.2 Queue Handler Summary

Worker receives:

```
{
  "eventId": "uuid",
  "tenantId": "...",
  "timestamp": "...",
  "payload": { ... }
}

```

Then batches → writes to blob → writes metadata record → marks complete.

8. Audit Event Model

Unified audit event JSON:

```
{
  "eventId": "uuid",
  "tenantId": "uuid",
  "timestamp": "2025-11-15T12:34:56Z",
  "actor": {
    "userId": "u-123",
    "roles": ["Editor"]
  },
  "action": "Document.Update",
  "objectType": "Document",
  "objectId": "doc-123",
  "requestId": "guid",
  "correlationId": "guid",
  "sourceIp": "4.3.2.1",
  "requestUrl": "/api/v1/documents/doc-123",
  "payload": {
    "before": {},
    "after": {}
  },
  "fieldsReturned": ["documentId", "title", "version",
"classification", "tags"],
  "system": {
    "application": "DocumentService",
    "version": "1.0.0"
  }
}

```

9. Multi-Tenancy Rules

- Every request must include `tenant_id` claim.
- API rejects multi-tenant attempts (e.g., filter without tenantId).
- Audit data strictly partitioned by tenantId.
- Compliance roles may have cross-tenant access if allowed via SOP.

10. Performance Considerations

- List/search endpoints paginated.
- Download endpoints streaming.
- Audit endpoints limit results by default (e.g., 200 items).
- Export API offloads large results to background processing.

11. Non-Functional Requirements

- **Availability:** 99.9%
- **Latency:** < 150ms for standard API calls
- **Audit Log Latency:** < 60 seconds to appear in metadata index
- **Security:** OIDC, RBAC/ABAC, encrypted storage, key rotation
- **Immutability:** Blob WORM policy per regulatory requirements